Проект StepPay

УТВЕРЖДАЮ

Автор проекта

_____ / подпись автора /

«____» _____ 2026 г.

ПЛАТФОРМА STEPPAY. ОПЛАТА ПО ШАГАМ В ЦИФРОВЫХ РУБЛЯХ

Функциональное описание

ЛИСТ УТВЕРЖДЕНИЯ

STEPPAY.00002-01 13 01-ЛУ

Подпись и дата / Инв. № подл. / Взам. инв. № / Инв. № дубл. (по ГОСТ 19.104-78 заполняются при выпуске)

УТВЕРЖДЕН
STEPPAY.00002-01 13 01-ЛУ

ПЛАТФОРМА STEPPAY. ОПЛАТА ПО ШАГАМ В ЦИФРОВЫХ РУБЛЯХ

Функциональное описание

STEPPAY.00002-01 13 01

Листов 27

2026

СОДЕРЖАНИЕ

1 ОБЩИЕ СВЕДЕНИЯ....5
1.1 Наименование и назначение....5
1.2 Состав комплекса....5
1.3 Нормативные ссылки....5
1.4 Термины и сокращения....6
2 ФУНКЦИОНАЛЬНОЕ НАЗНАЧЕНИЕ....7
2.1 Решаемые задачи....7
2.2 Участники и роли....7
2.3 Функциональные ограничения....8
3 ПРАВИЛА СДЕЛОК....9
3.1 Три режима....9
3.2 Этапы, резерв и выплаты....9
3.3 Приемка, автоприемка и споры....9
3.4 Сроки и аварийный выход....10
3.5 Приемщики и реестр....10
3.6 Комиссия....10
4 ФУНКЦИИ ПЛАТФОРМЫ....11
4.1 Регистрация и вход....11
4.2 Кошелек и чеки....11
4.3 Каталог услуг, чаты и задачи....11
4.4 Согласование условий и ИИ-помощник....12
4.5 Проекты: краудфандинг и гранты....12
4.6 Анкета автора и сверка с ФНС....12
4.7 Модерация и разделы администратора....13
4.8 Уведомления и обновление в реальном времени....13
4.9 Профиль, ключи и passkey....13
4.10 Демо-режим для показа....14
5 ПРОВЕРЯЕМОСТЬ И ДОВЕРИЕ....15
5.1 Контракт сделки и хеш условий....15
5.2 Журнал с цепочкой хешей....15
5.3 Подписи сторон....15
5.4 Якоря истории и свидетель....15
5.5 Смарт-контракты....16
6 БЕЗОПАСНОСТЬ....16
7 ПОЛЬЗОВАТЕЛЬСКИЙ ИНТЕРФЕЙС....18
8 АРХИТЕКТУРА И КОНФИГУРАЦИЯ....18
8.1 Состав и хранение данных....18
8.2 Внешние сервисы....19

8.3 Конфигурация.....19
9 КОНТРОЛЬ КАЧЕСТВА.....20
10 ВВОД В ЭКСПЛУАТАЦИЮ.....20
11 ОГРАНИЧЕНИЯ И ДАЛЬНЕЙШИЕ РАБОТЫ.....20
ПРИЛОЖЕНИЕ А Перечень экранов.....22
ПРИЛОЖЕНИЕ Б Перечень программных интерфейсов.....23
ПРИЛОЖЕНИЕ В Модель угроз и статус мер.....26

1 ОБЩИЕ СВЕДЕНИЯ

1.1 Наименование и назначение

Наименование: платформа StepPay (далее платформа, приложение). Обозначение документа: STEPPAY.00002-01 13 01. Платформа организует оплату работ по шагам в цифровых рублях: заказчик резервирует всю сумму, исполнитель получает деньги только за принятые этапы, а остаток возвращается автоматически. Основная идея: резерв подтверждает готовность платить, выплата привязана к принятому результату, никто не держит чужие деньги без срока.

Платформа охватывает три вида отношений: услуги (заказчик и исполнитель с независимым приемщиком споров), краудфандинг (проект собирает деньги у многих спонсоров, этапы принимают спонсоры) и гранты (проверенный грантодатель финансирует проект целиком). Для всех видов действует единое ядро правил, а эталонная реализация правил на смарт-контрактах позволяет перенести хранение денег в сеть.

1.2 Состав комплекса

Таблица 1 - Состав программного комплекса

Компонент	Каталог	Назначение
Ядро сделок	packages/engine	Чистые функции над состоянием: этапы, резерв, выплаты, споры, голосование, сроки, хеш условий, журнал, якоря, денежный рельс. Суммы в копейках
Смарт-контракты	packages/contracts	StepEscrow (эскроу по этапам), StepAnchor (реестр якорей), тестовый токен, испытания, скрипты развертывания
Программный интерфейс	apps/api	Сервер на Fastify: вход, сделки, платформа (услуги, проекты, чаты), администрирование, файлы, события в реальном времени, якоря
Веб-приложение	apps/web	Интерфейс на Next.js и React: адаптивный, светлая и темная темы, работает как приложение на телефоне
Документация	docs	Модель угроз, смарт-контракты, задание для аудита, порядок запуска, документы по ГОСТ

1.3 Нормативные ссылки

Документ оформлен с учетом ГОСТ 19.101-77, ГОСТ 19.104-78, ГОСТ 19.105-78, ГОСТ 19.106-78 и ГОСТ 19.402-78 (структура описания).

Описание сопровождается документом «Смарт-контракты StepEscrow и StepAnchor. Описание программы» (STEPPAY.00001-01 13 01).

1.4 Термины и сокращения

Таблица 2 - Термины и сокращения

Термин	Определение
Цифровой рубль	Денежная единица платформы. В прототипе эмулируется записями в кошельке, в контрактах заменяется токеном ERC-20
Сделка	Договоренность об оплате работы по этапам
Этап	Часть работы с фиксированной суммой, принимаемая и оплачиваемая отдельно
Резерв	Деньги, заморожены в сделке и доступные только для выплат по этапам или возврата
Приемщик	Независимая сторона, решающая спор между заказчиком и исполнителем
Passkey	Ключ входа и подписи в защищенном чипе устройства (стандарт WebAuthn), подтверждается отпечатком, лицом или PIN
Якорь	Снимок отпечатков всей истории платформы, корень которого публикуется вне сервера
ФНС	Федеральная налоговая служба России
ИНН	Идентификационный номер налогоплательщика

2 ФУНКЦИОНАЛЬНОЕ НАЗНАЧЕНИЕ

2.1 Решаемые задачи

- безопасная оплата услуг: исполнитель видит, что деньги зарезервированы, заказчик платит только за принятое;
- сбор денег на проект у многих спонсоров с приемкой этапов голосованием и возвратом остатка при провале;
- финансирование проектов грантодателями с проверкой авторов и контролем этапов;
- согласование условий: исполнитель разбивает работу на этапы с критериями готовности, заказчик проверяет и подписывает;
- разбор споров независимым приемщиком с перепиской и фото, запасной приемщик и сроки на случай молчания;
- защита от пропавшей стороны: сроки сбора, этапа и спора с автоматическим возвратом денег;
- доказуемость: условия защищены хешем, история событий цепочкой хешей, подписи проверяются на устройстве, история привязана к внешним якорям;
- модерация проектов и проверка авторов администратором со сверкой данных с ФНС.

2.2 Участники и роли

Таблица 3 - Роли в платформе

Роль	Возможности
Пользователь	Одна учетная запись на все роли: роль определяет конкретная сделка. Может быть заказчиком, исполнителем, спонсором, автором проекта
Заказчик	Выбирает услугу, пишет исполнителю, проверяет условия, подписывает, резервирует деньги, принимает или отклоняет этапы, открывает спор, отменяет сделку
Исполнитель	Размещает услуги, ведет чат, регистрирует задачу, согласует этапы, подписывает, сдает этапы, участвует в споре

Роль	Возможности
Спонсор	Поддерживает проекты взносами, голосует за приемку этапов, получает возврат при провале
Автор проекта	Заполняет анкету, подает проект на проверку, после одобрения собирает деньги или получает грант, сдает этапы
Грантодатель	Проверенный пользователь, назначенный администратором: финансирует гранты целиком и принимает этапы
Приемщик, запасной приемщик	Независимые стороны из реестра: видят спор, задают вопросы, решают его (запасной со второй половины срока)
Администратор	Проверяет проекты и авторов, назначает грантодателей, ведет реестр приемщиков, видит журнал действий. Вне демо работает только по passkey

2.3 Функциональные ограничения

- Деньги в приложении условные: цифровой рубль эмулируется, пополнение мгновенное (в демо), переводы наружу отключены. Подключение реального платежного канала не входит в объем.

- Подпись сторон это подпись ключом устройства или passkey, а не квалифицированная электронная подпись по 63-ФЗ.

- Для физического лица реестра в ФНС нет, проверяются только контрольные цифры ИНН.

- Контракты проверены в локальной сети, независимый аудит не проводился.

3 ПРАВИЛА СДЕЛОК

3.1 Три режима

Таблица 4 - Режимы сделок

Режим	Кто вносит деньги	Кто принимает этап	При отказе или молчании
Услуга (своя сделка)	Заказчик, всю сумму сразу	Заказчик; если молчит, автоприемка через срок (по умолчанию 3 дня)	Отказ только с причиной, этап уходит в спор и деньги за него заморожены до решения приемщика
Краудфандинг	Любые спонсоры до цели; работа начинается, когда собрана вся сумма	Спонсоры голосованием, вес равен взносу: больше половины за принимает	Половина веса и больше против или срок вышел: остаток возвращается спонсорам пропорционально
Грант	Грантодатель, всю сумму сразу	Грантодатель, автоприемки нет	Отказ проваливает этап, остаток возвращается грантодателю

3.2 Этапы, резерв и выплаты

Работа делится на этапы с названием, суммой и критериями готовности (до шести критериев на этап). Сумма сделки равна сумме этапов. Этапы идут строго по порядку, в работе не более одного. Работа начинается, когда резерв равен сумме сделки и все стороны подписали контракт. Выплата за принятый этап проводится сразу: исполнитель получает сумму за вычетом комиссии, остаток резерва уменьшается. Если сделка закрывается провалом этапа или отменой, остаток возвращается вкладчикам. В краудфандинге выплата и возврат делятся между спонсорами пропорционально их резервам методом наибольших остатков, поэтому копейки не теряются.

3.3 Приемка, автоприемка и споры

Исполнитель сдает этап с описанием и фото. Заказчик принимает его или отказывает с причиной. Для услуг отказ открывает спор: стороны переписываются, добавляют фото, приемщик может задавать вопросы и решает: выплатить исполнителю или вернуть деньги заказчику. Любая сторона спора может ответить, пока он не решен. Автоприемка срабатывает, если ответа нет в течение срока приемки (по умолчанию три дня, задается при создании и видна в контракте).

3.4 Сроки и аварийный выход

К условиям сделки относятся три срока, по умолчанию заданные платформой: краудфандинг 30 дней на сбор и 30 на этап, грант 60 дней на этап, услуга 30 дней на этап и 14 на спор. Если сбор не завершен в срок, сделка закрывается и взносы возвращаются. Если исполнитель не сдал этап в срок, остаток возвращается. Если приемщик не решил спор в срок, остаток возвращается заказчику. Возврат по сроку выполняется автоматически часами платформы, в контракте его может вызвать любой адрес. Срок этапа считается от начала работы над ним, срок спора от его открытия. Срок входит в хеш условий, когда задан.

3.5 Приемщики и реестр

Приемщики выбираются из реестра, который ведет администратор. Исполнитель при регистрации задачи выбирает основного и запасного приемщика, оба должны быть независимы от сторон и друг от друга. Репутация каждого публична: сколько споров решил, из них выплат и возвратов, сколько раз промолчал до срока. Запасной приемщик видит спор и может решить его со второй половины срока на спор, если основной не решил. Основной решает в любое время.

3.6 Комиссия

Платформа может удерживать комиссию с каждой выплаты за этап (в базисных пунктах, не более 10 процентов). Комиссия считается от суммы этапа с округлением вниз и зачисляется платформе. В прототипе значение по умолчанию равно нулю.

4 ФУНКЦИИ ПЛАТФОРМЫ

4.1 Регистрация и вход

Регистрация и вход выполняются по номеру телефона: на номер приходит шестизначный код (в демо код показывается на экране), при первом входе указывается имя. Код живет пять минут, число попыток и запросов ограничено. Токен входа действует 30 дней, пользователь может завершить все сессии кнопкой «Выйти на всех устройствах». Дополнительно предусмотрен вход по passkey без кода: устройство подтверждает отпечатком, лицом или PIN, пользователя определяет само устройство. Для администратора вне демо рабочая сессия возможна только после входа по passkey. В демо-режиме доступны демо-аккаунты по ролям.

4.2 Кошелек и чеки

У каждого пользователя есть кошелек цифрового рубля: свободные деньги и резерв в сделках. Раздел показывает баланс, резервы по сделкам, историю операций (пополнение, резерв, выплата, возврат, комиссия) и поясняет, что деньги хранятся на платформе Банка России (в прототипе это эмуляция). Пополнение мгновенное и доступно в демо-режиме, вне демо оно отключено, пока не подключен платежный канал. По каждой выплате за этап автоматически формируется чек с номером, суммой и описанием работ; раздел «Мои чеки» показывает их и итог за год. Когда деньги приходят, пользователь получает уведомление, а сумма на экране считается вверх.

4.3 Каталог услуг, чаты и задачи

Каталог состоит из вкладок «Проекты» и «Услуги» с поиском и фильтрами. Услуга содержит название, категорию (ремонт и строительство, разработка и дизайн, мероприятия, обучение, красота и здоровье, другое), описание от 20 символов, необязательную цену от и до шести фото работ. Исполнитель может создавать, редактировать и снимать услуги. Из карточки услуги заказчик пишет исполнителю: открывается чат по услуге.

Исполнитель после разговора регистрирует задачу: в чате появляется системное сообщение, у заказчика сделка в статусе «Согласование».

4.4 Согласование условий и ИИ-помощник

В статусе «Согласование» исполнитель разбивает работу на этапы вручную или с помощью подбора: описав задачу и бюджет, он получает предложение этапов по шаблонам (ремонт, разработка, мероприятия и другие) или от ИИ-помощника, если подключен ключ сервиса Anthropic. Для каждого этапа задаются сумма и критерии готовности. Затем исполнитель отправляет условия: платформа фиксирует контракт и вычисляет его хеш, исполнитель подписывает. Заказчик видит этапы и сумму, при необходимости исполнитель возвращает условия на правку (подписи при этом обнуляются), заказчик подписывает и резервирует деньги одной кнопкой «Подписать и зарезервировать».

4.5 Проекты: краудфандинг и гранты

Автор создает проект через мастер из пяти шагов: анкета автора, описание (название, категория из семи, краткая фраза, подробное описание от ста символов), этапы и суммы (с подбором этапов), материалы (обложка с обрезкой и масштабированием, до шести фото, PDF-документы до 5 МБ: смета, план, договор) и проверка с отправкой. Проект видит только автор и администраторы, пока он не одобрен. После одобрения краудфандинг открывается сразу: появляется сделка, спонсоры вносят любые суммы, работа начинается при полном сборе и подписи автора. Грант после одобрения виден грантодателям: тот, кто финансирует, резервирует всю сумму одной операцией. Этапы затем сдаются и принимаются по общим правилам. Администратор может вернуть проект на доработку с замечаниями или отклонить с причиной, автор получает уведомление.

4.6 Анкета автора и сверка с ФНС

Анкета заполняется один раз: статус (физическое лицо, самозанятый, ИП, организация), ИНН (10 цифр у организации, 12 у остальных, с проверкой

контрольных цифр), название организации или запись в ЕГРИП, почта для связи. Анкета хранится зашифрованной. Данные сверяются с открытыми сервисами ФНС: самозанятый по статусу плательщика налога на профессиональный доход, ИП и организации по выписке ЕГРИП и ЕГРЮЛ (ИНН найден, деятельность не прекращена, вид и название совпадают). Результат («Сверено с ФНС», «Расхождение с ФНС», «ФНС недоступна», «Без сверки») виден автору и администратору, обновляется при отправке проекта и по кнопке «Проверить заново». При расхождении администратор может одобрить проект только после явного подтверждения, это записывается в журнал действий.

4.7 Модерация и разделы администратора

Раздел «Проверка» администратора показывает очередь проектов по статусам (на проверке, доработка, опубликованы, отклонены) со счетчиками. Карточка проекта включает автора с результатом сверки, документы (открываются по временному билету), историю проверки и блок решения. Отдельные разделы: список грантодателей (добавление по номеру телефона), реестр приемщиков с репутацией, журнал действий администраторов и просмотров закрытых документов.

4.8 Уведомления и обновление в реальном времени

Изменения по сделкам и чатам приходят на устройство сразу через поток событий: всплывает уведомление, карточки сделок подсвечиваются, суммы пересчитываются, а при приемке этапа на открытой странице сделки от карточки выплаты расходится круг и точка этапа выскакивает. Поток подключается по временному билету на две минуты и переподключается автоматически. Автоматические действия часов (автоприемка, выход по срокам) сопровождаются уведомлениями участникам.

4.9 Профиль, ключи и passkey

В профиле показаны рейтинг, число принятых этапов и споров, настройки темы (светлая и темная), фото профиля с обрезкой по квадрату.

Раздел «Подпись контрактов» позволяет добавить passkey и ключи подписи устройства (до пяти активных), отозвать их, выйти на всех устройствах. Контракт подписывается ключом: подпись хранится в сделке вместе с открытым ключом и проверяется на устройстве без сервера.

4.10 Демо-режим для показа

Демо-сценарий из 11 шагов проводит зрителя по всему пути: Анна находит услугу Ивана и пишет в чат, Иван регистрирует задачу, разбивает ее на этапы и отправляет условия, Анна резервирует 300 000 рублей, Иван сдает этап, Анна принимает его, затем автор подает проект на проверку, администратор его одобряет, спонсоры вносят деньги, этап принимается голосованием, а следующий проваливается с возвратом остатка. Сценарий выполняется по шагам с пояснениями, данные можно сбросить. Демо-режим включается и выключается настройкой сервера; в публичной эксплуатации демо отключается.

5 ПРОВЕРЯЕМОСТЬ И ДОВЕРИЕ

5.1 Контракт сделки и хеш условий

Когда исполнитель отправляет условия, платформа фиксирует контракт: канонически записанные условия (участники, этапы с суммами и критериями, сроки, правила) и их хеш SHA-256. Любая правка условий меняет хеш и обнуляет подписи. Перед резервом и выплатой хеш проверяется: если условия подменены, выплаты блокируются. Карточка «Контракт» показывает условия, правила на понятном языке, подписи и позволяет пересчитать хеш на устройстве и скачать файл условий.

5.2 Журнал с цепочкой хешей

Каждое событие сделки (создание, отправка условий, подпись, резерв, сдача, приемка, отказ, голос, спор, выплата, возврат, закрытие по сроку) записывается в журнал, где запись хранит хеш предыдущей. Подмена, удаление и перестановка записей ломают цепочку. Карточка «Журнал» показывает события простыми словами, позволяет проверить цепочку на устройстве и скачать журнал для разбора спора.

5.3 Подписи сторон

Работа начинается только после подписей всех сторон под текущим хешем условий. Подпись выполняется ключом устройства (ECDSA P-256, закрытый ключ не покидает устройство) или passkey (WebAuthn): подписывается сообщение со сделкой, хешем условий, подписантом и временем. Для passkey подпись ставится после отпечатка, лица или PIN при каждой подписи. Сервер проверяет подпись, принадлежность ключа пользователю и свежесть. В демо возможна серверная демо-подпись, ее можно запретить настройкой.

5.4 Якоря истории и свидетель

Раз в час при изменениях платформа строит якорь: длина журнала и хеш последней записи по каждой сделке, длина и хеш журнала операций с деньгами, корень предыдущего якоря. Корень публикуется вне сервера (во

внешний журнал по адресу из настройки, в контракт StepAnchor). Сверка проверяет, что цепочка якорей цела, зафиксированные журналы не укорочены и не изменены, а кошельки восстанавливаются из журнала операций. Независимый свидетель по расписанию запоминает корни и подает тревогу, если история переписана. В журнале сделки виден ближайший якорь и результат сверки.

5.5 Смарт-контракты

Эталонная реализация правил сделок на Solidity (StepEscrow) повторяет ядро: три режима, подписи, голосование, споры, сроки, запасной приемщик, пропорциональные выплаты. Контракты и ядро сверяются общими сценариями и случайными прогонами. Отказ токена одному получателю не блокирует остальных (долг и вывод), токены с комиссией отклоняются. Прогон сделки в тестовой сети формирует отчет с адресами и транзакциями, который привязывается к сделке и виден в её карточке. Подробности в отдельном документе по ГОСТ.

6 БЕЗОПАСНОСТЬ

Меры защиты сгруппированы по угрозам модели угроз (приложение В).

Таблица 5 - Меры безопасности

Область	Мера
Вход	Токен с сроком 30 дней и отзывом, одноразовые коды с ограничением попыток, passkey, для администратора вне демо только сессия по passkey
Адреса запросов	Для потока событий и закрытых файлов используется временный билет на две минуты, постоянный токен в ссылки не попадает
Нагрузка	Ограничение частоты запросов по адресу и по группам (общая, вход, загрузки)
Заголовки и сайт	Запрет встраивания, nosniff, политика CSP, HSTS, строгий список разрешенных сайтов (CORS)
Файлы	Допустимы JPEG, PNG, WebP и PDF, проверка формата и размера; закрытые документы доступны автору и администраторам, шифруются AES-256-GCM
Личные данные	Анкета автора (ИНН, почта, название) хранится зашифрованной, телефон показывается маской
Деньги	Суммы целые в копейках, предельная сумма операции, единая очередь изменений, деление методом наибольших остатков, пополнение без оплаты отключено вне демо

Область	Мера
Подмена условий и истории	Хеш условий, цепочка журнала, подписи, якоря истории, сверка кошельков с журналом операций
Администрирование	Журнал действий администраторов и просмотров документов, назначение грантодателей и приемщиков только администратором
Мошенничество	Модерация проектов, сверка с ФНС, деньги только за принятые этапы
Зависание денег	Сроки сбора, этапа и спора с автоматическим возвратом, запасной приемщик

7 ПОЛЬЗОВАТЕЛЬСКИЙ ИНТЕРФЕЙС

Интерфейс адаптивный: на телефоне нижняя панель с вкладками «Сделки», «Каталог», «Чаты», «Профиль» и центральной кнопкой «Добавить» (услуга, проект на сбор средств, проект на грант), на компьютере боковая панель. Оформление выдержано в сине-белой гамме банковского приложения: шрифт Exo 2, крупные цифры сумм с легким знаком рубля, плоские блоки без рамок, градиенты в синих карточках и главных кнопках, объемные картинки (кошелек, ступени, сейф, чек, ракета, росток, папка, чат). Доступны светлая и темная темы.

Движение несет смысл: списки появляются волной, полосы этапов заполняются по очереди, суммы пересчитываются и зеленеют при поступлении, обновленные карточки подсвечиваются, выплата сопровождается расходящимся кругом. Для пользователей с настройкой уменьшенного движения пространственные анимации отключаются, смысловые изменения остаются. Прогресс сделки показан полосой с делением по числу этапов без цифр. Подсказки в полях общие, без примеров. Перечень экранов приведен в приложении А.

8 АРХИТЕКТУРА И КОНФИГУРАЦИЯ

8.1 Состав и хранение данных

Ядро сделок это чистые функции над состоянием, каждое действие применяется к копии и либо завершается целиком, либо отклоняется с понятной ошибкой. Сервер выполняет все изменения через одну очередь, поэтому гонки между запросами исключены в пределах одного экземпляра. Состояние сделок, учетные записи, данные платформы (услуги, проекты, чаты, журнал действий, якоря) и файлы хранятся в базе данных PostgreSQL; без нее данные хранятся в памяти (для разработки). Закрытые файлы и анкеты авторов шифруются перед записью. Веб-приложение обращается к серверу по защищенному каналу и не хранит секретов, ключи подписи лежат в защищенном хранилище браузера.

8.2 Внешние сервисы

Таблица 6 - Внешние сервисы

Сервис	Для чего	Обязателен
PostgreSQL	Хранение состояния и файлов	Для боевого запуска
Anthropic API	Подбор этапов ИИ-помощником	Нет, есть запасной подбор по шаблонам
Сервисы ФНС (statusnpd.nalog.ru, egrul.nalog.ru)	Сверка анкеты автора	Нет, при недоступности решает администратор
Сеть Ethereum (тестовая) и RPC-узел	Развертывание контрактов и публикация якорей	Нет
Внешний журнал якорей	Публикация корней якорей вне сервера	Нет, но без него защита истории слабее
Провайдер СМС	Доставка кодов входа	Для публичного запуска (в демо код на экране)

8.3 Конфигурация

Таблица 7 - Основные переменные окружения сервера

Переменная	Назначение
AUTH_SECRET	Секрет подписи токенов, обязателен в боевом запуске
FILE_KEY	Ключ шифрования закрытых файлов и анкет (32 байта в hex или base64); без него выводится из AUTH_SECRET
CORS_ORIGIN	Точный адрес сайта (несколько через запятую); нужен для входа и passkey
DATABASE_URL	Подключение к PostgreSQL
DEMO_MODE	off отключает демо (сценарий, сброс, демо-аккаунты)
ADMIN_PHONES	Номера администраторов
ADMIN_REQUIRE_PASSKEY	Требование passkey от администраторов, по умолчанию включено вне демо
SIGNATURE_POLICY	device или passkey: запрет серверной демо-подписи; passkey: подписывать только passkey
ALLOW_TOPUP	Разрешает пополнение без оплаты вне демо
ANCHOR_URL, ANCHOR_TOKEN, ANCHOR_EVERY_MIN	Публикация корней якорей и период
ANTHROPIC_API_KEY, ANTHROPIC_MODEL	Ключ и модель ИИ-помощника
NEXT_PUBLIC_API_URL (сайт)	Адрес сервера для веб-приложения, задается при сборке

9 КОНТРОЛЬ КАЧЕСТВА

Качество проверяется автоматическими испытаниями: ядро сделок 72 испытания и свойства на случайных последовательностях (400 хаотичных и 80 направляемых прогонов, более двадцати условий после каждого шага), смарт-контракты 48 испытаний с инвариантами и дифференциальными прогонами, сравнивающими контракт и ядро, сервер 86 испытаний (права доступа, вход и passkey, шифрование, сверка с ФНС, якоря, сроки, реестр приемщиков, ограничения). Интерфейс проверялся просмотром экранов на ширинах от 360 до 1280 пикселей в светлой и темной темах, а работа passkey и входа сквозным прогоном в браузере с виртуальным аутентификатором. Скрипт scripts/smoke.mjs проверяет развернутый сервер и сайт (заголовки, CORS, закрытость адресов, режим демо, passkey, якоря).

10 ВВОД В ЭКСПЛУАТАЦИЮ

Порядок запуска описан в docs/deploy.md: сначала сервер на Railway с базой PostgreSQL и переменными окружения, затем сайт на Vercel с адресом сервера, затем адрес сайта вписывается в CORS_ORIGIN. После запуска выполняется автоматическая проверка и ручные проверки: вход администратора с passkey, подпись контракта passkey на телефоне, сверка с ФНС на реальных ИНН, публикация якорей и запуск свидетеля, прогон в публичной тестовой сети. Постоянный адрес сайта выбирается сразу, так как passkey привязан к домену. Резервную копию базы нужно делать до обновлений, а копии, сделанные до включения шифрования, удалить или хранить как секретные.

11 ОГРАНИЧЕНИЯ И ДАЛЬНЕЙШИЕ РАБОТЫ

Таблица 8 - Ограничения и планируемые доработки

Область	Состояние
Платежи	Цифровой рубль эмулируется. Нужны платежный канал или интеграция с оператором, СМС-провайдер, процедуры идентификации (KYC)
Юридическая сторона	Подпись не квалифицированная (63-ФЗ), нужны согласие на обработку персональных данных (152-ФЗ), договорная база, взаимодействие с оператором платформы цифрового рубля

Область	Состояние
Контракты	Независимый аудит, запуск в публичной сети, проверка на реальном токене цифрового рубля
Данные авторов	Телефон хранится открытым; ключ шифрования находится рядом с сервером
Вход	СМС остается запасным входом; passkey не обязателен для обычных пользователей
Приемщики	Нет залога и оспаривания решения, репутация только счетчики
Масштабирование	Один экземпляр сервера, состояние хранится целиком, нужны блокировки в базе для нескольких экземпляров
Эксплуатация	Мониторинг, резервное копирование, журналирование сервера
Продукт	Push и email-уведомления, мобильное приложение, частичные решения по спору, вывод комиссии в интерфейс

ПРИЛОЖЕНИЕ А

(справочное)

Перечень экранов

Таблица 9 - Экраны приложения

Экран	Адрес	Назначение
Вход и регистрация	/login	Телефон и код, вход по passkey, вход в демо
Демо-сценарий	/demo	Пошаговый показ полного пути с пояснениями
Сделки	/deals	Кошелек-карточка, быстрые действия, список сделок заказчика и исполнителя
Сделка	/deals/{id}	Прогресс, контракт, журнал, цепочка, этапы и действия по роли, споры, сбор средств
Кошелек	/wallet	Баланс, резервы, история операций, пополнение
Чеки	/receipts	Чеки по выплатам и итог за год
Каталог	/catalog	Проекты и услуги, поиск, фильтры
Услуга	/services/{id}, /services/new, /services/{id}/edit	Карточка услуги, создание и правка, чат с исполнителем
Проект	/projects/{id}	Карточка проекта, сбор или грант, этапы, решение администратора
Мастер проекта	/projects/{id}/edit	Пять шагов подачи проекта
Чаты	/chats, /chats/{id}	Список чатов и переписка, регистрация задачи, выбор приемщиков
Профиль	/profile	Показатели, ключи подписи и passkey, тема, выход на всех устройствах
Проверка	/admin	Очередь проектов, грантодатели, реестр приемщиков, журнал действий

ПРИЛОЖЕНИЕ Б

(справочное)

Перечень программных интерфейсов

Сервер предоставляет 84 программных интерфейсов (адреса и методы HTTP). Все, кроме входа, справочных и служебных, требуют входа и проверяют права по роли.

Таблица 10 - Вход и учетная запись

Метод	Адрес
GET	/auth/demo-users
POST	/auth/demo
POST	/auth/otp/request
POST	/auth/otp/verify
POST	/auth/passkey/challenge
POST	/auth/passkey/login
GET	/users/search
POST	/me/profile
GET	/me
GET	/wallet
POST	/auth/ticket
POST	/auth/logout-all
POST	/wallet/topup
GET	/me/keys
POST	/me/keys
POST	/me/passkeys
POST	/me/keys/:id/revoke
GET	/me/stats
GET	/receipts
GET	/meta
GET	/me/author
POST	/me/author

Таблица 11 - Сделки и этапы

Метод	Адрес
GET	/templates
GET	/deals
GET	/deals/:id
POST	/deals/:id/chain
GET	/deals/:id/journal
GET	/deals/:id/contract
POST	/deals
GET	/ai/status
POST	/ai/plan
GET	/events
GET	/deals/:id/anchors
POST	/deals/:id/fund
POST	/deals/:id/terms
POST	/deals/:id/propose
POST	/deals/:id/sign
POST	/deals/:id/reopen
POST	/deals/:id/cancel
POST	/deals/:id/stages/:stageId/submit
POST	/deals/:id/stages/:stageId/approve
POST	/deals/:id/stages/:stageId/reject

Метод	Адрес
POST	/deals/:id/stages/:stageId/vote
POST	/deals/:id/stages/:stageId/dispute
POST	/deals/:id/stages/:stageId/reply
POST	/deals/:id/stages/:stageId/resolve

Таблица 12 - Услуги и чаты

Метод	Адрес
GET	/services
GET	/my/services
GET	/services/:id
POST	/services
POST	/services/:id/update
POST	/services/:id/remove
POST	/services/:id/chat
GET	/chats
GET	/chats/:id
POST	/chats/:id/messages
POST	/chats/:id/task

Таблица 13 - Проекты, анкета автора

Метод	Адрес
GET	/projects
GET	/my/projects
GET	/projects/:id
POST	/projects
POST	/projects/:id/update
POST	/projects/:id/submit
POST	/projects/:id/grant

Таблица 14 - Администрирование и реестры

Метод	Адрес
GET	/admin/summary
GET	/admin/projects
POST	/admin/projects/:id/decision
POST	/admin/projects/:id/fns
GET	/admin/audit
GET	/admin/grantors
POST	/admin/grantors
GET	/arbiters
POST	/admin/arbiters

Таблица 15 - Файлы, якоря, служебные

Метод	Адрес
GET	/health
GET	/demo/script
POST	/demo/reset
POST	/demo/step
POST	/uploads
GET	/uploads/:id
POST	/system/tick
GET	/anchors

Метод	Адрес
GET	/anchors/latest
GET	/anchors/verify
POST	/system/anchor

ПРИЛОЖЕНИЕ В

(справочное)

Модель угроз и статус мер

Выписка из docs/threat-model.md: идентификатор угрозы, описание, серьезность и статус. Статусы: закрыто (есть защита и испытание), частично (защита есть, остаются оговорки), открыто.

Таблица 16 - Угрозы и статус мер

№	Угроза	Серьезность	Статус
T1	Исполнитель или заказчик подменяет условия после согласования	Высокая	Закрыто
T2	Оператор сервера правит базу: меняет суммы, записи, подписи	Высокая	Закрыто при включенной публикации якорей
T3	Двойная трата, гонки между запросами	Высокая	Закрыто
T4	Кража токена входа	Высокая	Закрыто
T5	Перехват кода из SMS, подмена номера	Высокая	Частично
T6	Кража ключа подписи через XSS или доступ к разблокированному браузеру	Высокая	Закрыто для пользователей с passkey
T7	Любой пользователь пополняет кошелек без оплаты	Высокая для продукта	Закрыто настройкой
T8	Присвоение роли администратора или грантодателя	Высокая	Закрыто при включенном требовании
T9	Автор краудфандинга пропал, не сдает этапы	Высокая	Закрыто
T10	Спор не решается: приемщик молчит или недоступен	Высокая	Закрыто
T11	Недобросовестный или подкупленный приемщик	Средняя	Частично
T12	Заказчик не отвечает, исполнитель получает деньги автоприемкой за некачественную работу	Средняя	Частично
T13	Заказчик отказывает без причины и затягивает	Средняя	Закрыто
T14	Фейковые проекты, мошенничество при сборе средств	Высокая	Частично
T15	Утечка документов проектов и ИНН	Высокая	Закрыто шифрованием, ключ рядом
T16	Вредоносные файлы и перегрузка	Средняя	Закрыто
T17	Перебор и перегрузка API, подбор данных	Средняя	Закрыто
T18	Подмена источника запросов (CORS, CSRF)	Низкая	Закрыто
T19	Переполнение и ошибки округления денег	Средняя	Закрыто
T20	Ошибка в смарт-контракте	Высокая	Частично
T21	Заморозка денег в контракте из-за таких же пробелов (T9, T10)	Высокая	Закрыто
T22	Злоупотребление подписью как юридической	Средняя	Закрыто в тексте
T23	Регуляторные ограничения	Средняя	Учтено
T24	Потеря устройства с ключом	Низкая	Закрыто
T25	Демо-режим в продакшене: общие аккаунты, сброс данных	Высокая	Закрыто настройкой

ЛИСТ РЕГИСТРАЦИИ ИЗМЕНЕНИЙ

Изм.	Номера листов (страниц) измененных / замененных / новых / аннулированных	Всего листов (страниц) в докум.	№ докум.	Входящий № сопроводит. докум. и дата	Подп.	Дата